SIMATS ENGINEERING

ASSESSMENT TOOL 1

COURSE NAME: Ethical Hacking
COURSE CODE: ITA1436

COURSE OUTCOME COVERED
CO2: Execute foot printing in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.
Assessment Tool Weightage: 30%
Duration: 90 min Total Marks: 50

Report Analysis

Questions

1.A security analyst performed a network scan on the target 192.168.1.10 using the Nmap tool. The report identified several open ports, including HTTP (80), SSH (22), and MySQL (3306), along with the operating system and service versions. Analyze the report and explain the security risks associated with the identified services. Discuss how an attacker could exploit these services and recommend suitable security measures to protect the target system.
Answer:

1.1 Introduction

Nmap (Network Mapper) is an open-source network scanning tool used by cybersecurity professionals to discover hosts, identify open ports, determine service versions, and estimate the operating system of a target system. It is widely used during authorized penetration testing and vulnerability assessment.

In the given scenario, a security analyst scans the target IP address 192.168.1.10. The report identifies three open ports: SSH (22), HTTP (80), and MySQL (3306), along with operating system and service-version information.

An open port indicates that a service is listening for network connections. However, an open port alone does not prove that the service is vulnerable. The actual risk depends on the service configuration, software version, authentication controls, network exposure, and available security patches.

1.2 Analysis of the Nmap Report

Port	Service	Purpose	Potential security risk
22/TCP	SSH	Remote command-line administration	Password attacks, compromised credentials, outdated SSH software, weak authentication
80/TCP	HTTP	Web application communication	Web application vulnerabilities, unencrypted traffic, session exposure, information disclosure

3306/TCP	MySQL	Database access	Unauthorized database access, weak credentials, exposed sensitive information, vulnerable database software

The operating system and service-version information also help determine whether the target uses outdated or unsupported software. If exact versions are revealed, they can be compared against trusted vulnerability databases and vendor security advisories.

1.3 Security Risks and Possible Exploitation

A. SSH – Port 22

Security risks

- Weak passwords and reused credentials can allow unauthorized access.
- Password-based login exposed to untrusted networks may be targeted by brute-force or credential-stuffing attacks.
- Outdated SSH implementations may contain known vulnerabilities.
- Poorly configured administrator accounts may provide excessive privileges.
- Unrestricted remote access increases the attack surface.

Possible attack scenario

An attacker who can reach the SSH service may attempt to authenticate using stolen credentials or exploit a known vulnerability in an outdated implementation. If authentication succeeds, the attacker could access files, execute commands with the account's privileges, or attempt privilege escalation. The actual impact depends on the account permissions and system configuration.

Recommended security measures

1. Disable direct root login and use individual administrative accounts.
2. Prefer SSH key-based authentication and disable password authentication where operationally appropriate.
3. Enforce multi-factor authentication for administrative access where supported.
4. Restrict SSH access through a VPN, firewall allowlist, or dedicated management network.
5. Apply security updates to the SSH server and underlying operating system.
6. Use rate limiting and monitoring to identify repeated failed login attempts.
7. Review account permissions and remove unused accounts and SSH keys.

8. Log administrative access and alert on suspicious login patterns.

B. HTTP – Port 80

Security risks

- Standard HTTP does not encrypt application traffic between the client and server.
- Login credentials, session cookies, or personal information may be exposed if transmitted without appropriate protection.
- Vulnerable web applications may suffer from SQL injection, cross-site scripting (XSS), broken access control, or insecure file uploads.
- Default pages, server banners, directory listings, and error messages may disclose useful technical information.
- Outdated web-server software or insecure configurations may expose known vulnerabilities.

Possible attack scenario

An attacker who can intercept unencrypted traffic on a suitable network path may obtain information transmitted through HTTP. Alternatively, the attacker may probe an authorized-to-test web application for weaknesses in input validation or access control. A successful vulnerability exploit could expose user information or permit unauthorized application actions.

Recommended security measures

1. Configure HTTPS using valid TLS certificates and redirect HTTP requests to HTTPS.
2. Use secure session-cookie attributes, including Secure, HttpOnly, and appropriate SameSite settings.
3. Patch the web server, frameworks, plugins, and application dependencies.
4. Validate input on the server and use parameterized database queries.
5. Enforce authorization checks on every protected resource.
6. Disable directory listing and remove unnecessary server-banner disclosures.
7. Deploy a web application firewall (WAF) where appropriate.
8. Perform regular vulnerability scanning and authorized web application penetration testing.
9. Use secure HTTP headers and maintain application security logs.

Important: HTTPS protects traffic in transit but does not automatically fix application vulnerabilities. The application must also implement secure authentication, authorization, input handling, and session management.

C. MySQL – Port 3306

Security risks

- Public or unnecessary network exposure increases the chance of unauthorized database access.
- Weak or reused database passwords may be compromised.
- Excessive database privileges can allow an attacker to read, modify, or delete sensitive information.
- Outdated MySQL versions may contain known security vulnerabilities.
- Insecure database connections may expose information to interception.
- Poor backup protection may allow stolen or compromised credentials to result in data loss.

Possible attack scenario

If MySQL is accessible from an untrusted network, an attacker may attempt to authenticate using compromised credentials or exploit a known weakness in an outdated server. If access is obtained, the attacker may read customer records, alter application data, or delete information depending on the permissions granted to the compromised account.

Recommended security measures

1. Do not expose MySQL directly to the public internet.
2. Bind the database service to a private interface when remote access is unnecessary.
3. Configure firewall rules to allow connections only from approved application servers and administrators.
4. Use strong, unique credentials and rotate exposed credentials immediately.
5. Apply the principle of least privilege to database accounts.
6. Enable TLS for database connections where appropriate.
7. Keep MySQL updated with supported security releases.
8. Enable database audit logging and monitor unusual queries or login attempts.
9. Encrypt sensitive backups, restrict backup access, and test restoration procedures.
10. Separate database, application, and management networks where feasible.

1.4 Risk Prioritization

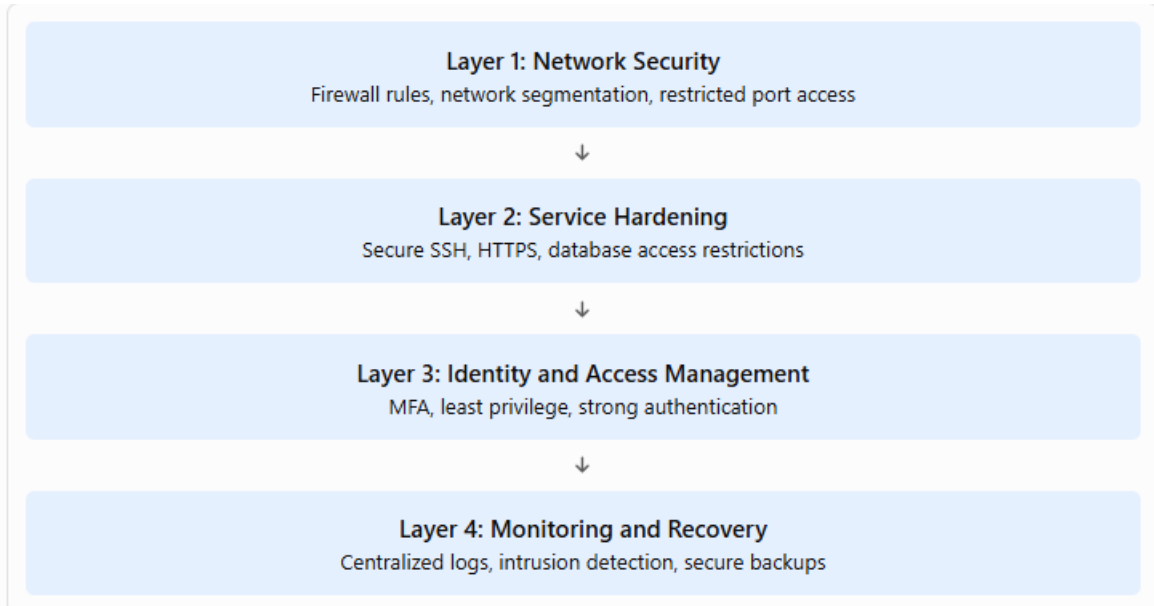
The following ratings are preliminary assessments based on the limited information in the

question, not confirmed vulnerability scores.

Finding	Preliminary priority	Reason
MySQL exposed to untrusted networks	High	Direct access could expose critical database information
SSH accessible from untrusted networks	High if unrestricted	Remote authentication creates an administrative attack surface
HTTP without HTTPS protection	Medium to High	Traffic confidentiality and session protection may be inadequate
Outdated operating system or services	Depends on version	Known exploitable vulnerabilities may significantly increase risk

The actual severity should be confirmed through authorized testing, version verification, configuration review, and assessment of the data and privileges involved.

1.5 Defense-in-Depth Strategy



Regular vulnerability assessments and penetration tests should verify whether these controls are effective. Findings must be prioritized according to exploitability, business impact, and exposure.

1.6 Conclusion

The Nmap report identifies SSH, HTTP, and MySQL as potential attack surfaces on 192.168.1.10. Each service has legitimate operational uses, but incorrect configurations, weak credentials, excessive network exposure, and outdated software can introduce security risks. SSH should be restricted and hardened, HTTP should be secured using HTTPS, and MySQL should be isolated from untrusted networks. Combining patch management, access controls,

network segmentation, monitoring, and regular authorized testing can significantly reduce the system's exposure to cyberattacks.

2.A phishing awareness campaign was conducted for employees of ABC Technologies Pvt. Ltd. using the GoPhish tool. The report indicates that 40% of employees clicked the phishing link, 20% entered their login credentials, and several users downloaded a malicious attachment. Analyze the report and identify the security weaknesses demonstrated by the employees. Recommend suitable user awareness programs, email security controls, and organizational policies to reduce the risk of successful social engineering attacks.

Answer:

2.1 Introduction

Phishing is a social engineering technique in which an attacker impersonates a trusted organization or individual to persuade victims to click malicious links, disclose credentials, or download harmful attachments.

GoPhish is an open-source phishing simulation platform used by security teams to evaluate employee awareness and improve organizational security. When used with proper authorization, it helps measure employee responses to simulated phishing messages without conducting real credential theft or deploying actual malware.

ABC Technologies Pvt. Ltd. conducted a phishing awareness campaign with the following results.

2.2 Analysis of Campaign Results



The results reveal three major weaknesses:

1. High link-click rate: 40% of employees interacted with the simulated phishing link, suggesting that suspicious messages were not consistently identified before clicking.

2. Credential disclosure: 20% entered their login credentials, demonstrating a significant risk of account takeover if a similar real-world attack succeeded.

3. Unsafe attachment handling: Several employees downloaded a malicious simulation attachment, indicating insufficient caution around unexpected files and possible gaps in endpoint protection.

The campaign demonstrates susceptibility to social engineering, but it does not prove that every employee lacks awareness. Results may vary by department, role, message type, and the realism of the simulation.

2.3 Security Weaknesses Demonstrated by Employees

A. Lack of sender verification

Employees may have trusted the display name or apparent identity of the sender without checking the actual email address and domain.

Risk: Attackers can impersonate managers, vendors, IT support staff, or business partners to request sensitive information.

Control: Train employees to verify sender domains, inspect unexpected requests, and independently confirm unusual instructions through a known communication channel.

B. Failure to inspect suspicious links

Employees may have clicked links because the message used urgent language, an account-warning notice, a prize, or an apparent business requirement.

Risk: The destination could host credential-harvesting pages, drive-by attacks, or redirects to malicious websites.

Control: Teach users to inspect link destinations safely, avoid unexpected login links, and access organizational services using known bookmarks or official URLs.

C. Poor credential-protection practices

The 20% credential-entry rate suggests that some employees trusted the simulated login page or did not recognize signs of impersonation.

Risk: Stolen credentials could enable unauthorized access to email, cloud applications, internal systems, or sensitive company data.

Control: Deploy phishing-resistant multi-factor authentication where feasible, enforce strong authentication policies, monitor anomalous sign-ins, and provide clear instructions for reporting suspected credential exposure.

MFA reduces risk, but not all MFA methods provide equal protection. Phishing-resistant methods, such as FIDO2 security keys or passkeys, are preferable for high-risk accounts.

D. Unsafe attachment handling

Downloading unexpected attachments may expose users to malicious documents, executable files, scripts, or archive files containing harmful content.

Risk: Depending on the file and execution behavior, a successful attack could lead to malware infection, data theft, ransomware, or unauthorized access to internal resources.

Control: Use email attachment scanning, sandboxing, endpoint detection and response (EDR), restricted execution policies, and application allowlisting where appropriate.

E. Insufficient incident reporting

The supplied report does not state how many employees reported the simulation. Therefore, the organization's reporting capability cannot yet be quantified.

Risk: If employees fail to report suspicious messages, security teams may not discover campaigns until multiple accounts or systems are affected.

Control: Provide a simple “Report Phishing” button, communicate reporting procedures, and recognize prompt reporting rather than punishing good-faith mistakes.

2.4 Recommended Employee Awareness Program

ABC Technologies should implement a continuous, role-based security awareness program.

Training activity	Implementation	Expected outcome
Phishing awareness sessions	Explain spoofed senders, suspicious links, urgency, and impersonation	Better recognition of phishing attempts
Safe-link exercises	Demonstrate how to inspect destinations without opening suspicious links	Reduced unsafe clicking
Attachment safety training	Teach employees to verify unexpected files and report suspicious attachments	Reduced malware exposure
Credential security	Promote password managers, unique passwords, and phishing-resistant MFA	Lower account-compromise risk
Incident reporting drills	Practice reporting suspicious emails through approved channels	Faster detection and response
Targeted refresher training	Offer additional support to teams with repeated simulation failures	Measurable improvement over time

Training should be short, frequent, accessible, and supported by management. Simulations should be educational rather than humiliating, and employee-level results should be handled confidentially.

2.5 Recommended Email Security Controls

The organization should implement the following technical safeguards.

1. SPF (Sender Policy Framework)

SPF identifies which servers are authorized to send email for a domain. Proper configuration

can help receivers detect unauthorized senders, but SPF alone does not prevent all impersonation.

2. DKIM (DomainKeys Identified Mail)

DKIM adds a cryptographic signature to email, allowing receiving systems to verify that signed portions of a message have not been altered and that the signature is associated with a domain.

3. DMARC (Domain-based Message Authentication, Reporting and Conformance)

DMARC builds on SPF and DKIM by specifying how receiving systems should handle messages that fail alignment and authentication checks. Organizations should deploy it progressively, monitor reports, and move toward an appropriate enforcement policy.

4. Secure Email Gateway

A secure email gateway can identify suspicious URLs, impersonation attempts, spam, and dangerous attachments before messages reach employees.

5. URL and attachment protection

Use time-of-click URL inspection, safe browsing controls, attachment sandboxing, and malware scanning. Controls should also account for encrypted archives and newly observed malicious files.

6. Multi-factor authentication

Require MFA for email, remote access, administrative accounts, and other critical services. Prioritize phishing-resistant methods for sensitive accounts.

7. Endpoint security

Deploy centrally managed EDR or equivalent endpoint protection, keep systems patched, and restrict unauthorized scripts and executable files.

2.6 Organizational Policies and Incident Response

ABC Technologies should introduce or strengthen the following policies:

- Acceptable Use Policy: Define appropriate use of corporate email, devices, and internet services.
- Email Security Policy: Establish procedures for suspicious messages, attachments, external links, and impersonation attempts.
- Credential Management Policy: Require unique credentials, secure storage, MFA, and prompt reporting of exposed credentials.
- Incident Response Policy: Define reporting channels, escalation responsibilities, evidence preservation, containment, and recovery.

- Access Control Policy: Apply least privilege and promptly revoke unnecessary access.
- Security Awareness Policy: Require induction training and periodic refresher exercises.
- Privacy and Monitoring Policy: Explain how simulation data is collected, protected, reviewed, and used for improvement.

If a real phishing incident occurs, the response team should investigate the message, block malicious indicators where appropriate, revoke affected sessions, reset exposed credentials, examine sign-in logs, and isolate affected devices when necessary. If malware may have executed, endpoint investigation should determine the extent of compromise before recovery.

2.7 Metrics for Measuring Improvement

The next GoPhish campaign should compare results with the baseline rather than relying only on training attendance.

Metric	Baseline	Improvement objective
Link-click rate	40%	Reduce over successive campaigns
Credential-submission rate	20%	Reduce toward zero
Attachment interaction rate	Not quantified	Establish baseline and reduce
Phishing-reporting rate	Not supplied	Measure and increase
Time to report	Not supplied	Measure and shorten
Repeat susceptibility	Not supplied	Track improvement with appropriate privacy safeguards

These are proposed performance measures, not guaranteed outcomes. The organization should compare similar campaigns over time and avoid treating a single simulation as a complete measure of security awareness.

2.8 Conclusion

The GoPhish report identifies weaknesses in phishing recognition, credential protection, and attachment handling. The 40% click rate and 20% credential-entry rate demonstrate a meaningful risk of successful social engineering. ABC Technologies should combine ongoing employee training with SPF, DKIM, DMARC, secure email gateways, attachment scanning, endpoint protection, and phishing-resistant MFA. Clear reporting procedures and measurable follow-up simulations will help determine whether the controls are working. A combination of human awareness, technical safeguards, and an effective incident response process is more reliable than training alone.

3.A DNS assessment report generated using the Dig tool shows that the organization's DNS server permits a successful DNS Zone Transfer (AXFR), exposing internal hostnames, mail servers, and DNS records. Analyze the report and explain the security implications of the exposed information. Discuss how attackers could exploit these findings and recommend best practices to secure the DNS infrastructure.

Answer:

3.1 Introduction

The Domain Name System (DNS) translates domain names into IP addresses and helps locate services such as websites and mail servers. DNS zone transfers allow DNS servers to replicate authoritative zone data between primary and secondary servers.

The AXFR query type is used for a full DNS zone transfer. When a DNS server permits unrestricted zone transfers to unauthorized hosts, the result may expose internal hostnames, mail servers, subdomains, and other DNS records.

In the given scenario, a dig assessment successfully performs an AXFR transfer, revealing organizational DNS information. This indicates a potential access-control misconfiguration that should be investigated and corrected.

3.2 Analysis of the DNS Assessment Report

A successful AXFR response may disclose the following:

Exposed information	**Security significance**
Internal hostnames	Reveals naming conventions and potentially sensitive systems
Mail server records (MX)	Identifies email infrastructure that may be targeted by attackers
A and AAAA records	Reveals IPv4 and IPv6 addresses associated with DNS names
Subdomains	Identifies applications, portals, test systems, and additional services
CNAME records	May reveal service dependencies or misconfigured aliases
TXT records	May expose domain-verification details and email security policies
Service records (SRV)	May disclose the names and ports of certain services

A DNS record is not automatically confidential merely because it appears in a zone transfer. The security concern is that AXFR may expose a larger and more structured collection of records than the organization intends to disclose.

3.3 Security Implications

A. Information disclosure and reconnaissance

An attacker may use the transferred records to map the organization's infrastructure, identify naming patterns, and discover systems that are not obvious through ordinary public DNS queries.

B. Identification of high-value targets

Mail servers, remote-access gateways, administrative portals, and development systems may be identified for further investigation. Their presence in DNS does not prove that they are vulnerable, but it can help prioritize subsequent reconnaissance.

C. Targeted phishing and impersonation

Knowledge of internal hostnames, department-related subdomains, and mail infrastructure can make phishing messages more convincing. Attackers may impersonate IT support or use discovered organizational terminology in social engineering attempts.

D. Discovery of forgotten or test systems

Zone data may contain obsolete hostnames or records for staging, development, and legacy systems. If those systems remain active and are inadequately protected, they may provide an additional attack surface.

E. Improved attack planning

The combined information can help an attacker construct an infrastructure map, correlate DNS records with publicly accessible services, and prioritize further testing.

Technical distinction: A successful AXFR transfer does not itself provide remote access to the listed systems, modify DNS records, or prove that the organization has been compromised. It is an information-disclosure finding that may facilitate later attacks.

3.4 Recommended DNS Security Measures

1. Restrict zone transfers

Configure authoritative DNS servers to permit AXFR only to explicitly authorized secondary DNS servers. Deny transfer requests from all other clients.

2. Use TSIG authentication

Transaction Signature (TSIG) can authenticate and protect the integrity of DNS messages used for zone transfers between supporting servers. Use strong shared secrets and manage their rotation securely.

3. Apply network access controls

Use firewalls and appropriate network restrictions to limit DNS administrative and replication traffic to trusted hosts.

4. Separate internal and external DNS

Use split-horizon DNS or separate internal and public DNS views where appropriate. Publish only the records needed for external services, while maintaining internal records in appropriately restricted infrastructure.

5. Review zone records regularly

Remove obsolete records, validate subdomain ownership, and document which systems should be publicly resolvable. Avoid exposing sensitive naming conventions unnecessarily.

6. Patch and harden DNS software

Maintain supported DNS software, disable unnecessary functionality, and apply vendor security recommendations.

7. Monitor DNS activity

Log and investigate unexpected AXFR requests, repeated unauthorized transfer attempts, and unusual administrative changes. Alerts should distinguish legitimate secondary-server transfers from suspicious activity.

8. Validate DNSSEC where appropriate

DNS Security Extensions (DNSSEC) provide origin authentication and integrity protection for signed DNS data. DNSSEC does not prevent unauthorized zone transfers, so it must not be treated as a replacement for AXFR access controls.

3.5 Safe Validation Using Dig

During an authorized assessment, the analyst can test the organization's own DNS server using a command of the following form:

dig @<authorized-dns-server> <organization-zone> AXFR

Replace the placeholders with the authorized DNS server address and the organization's zone name. A successful response containing the zone records indicates that the transfer was permitted from the testing source.

After restricting AXFR, repeat the test from an unauthorized test host and verify that the server refuses or denies the transfer. Then confirm that the approved secondary DNS server can still replicate the zone successfully.

Testing must be limited to systems for which explicit authorization has been obtained.

3.6 Conclusion

The successful AXFR finding indicates that DNS zone-transfer access controls may be incorrectly configured. The exposed records can assist attackers with reconnaissance, targeted

phishing, and identification of potentially sensitive systems. The organization should restrict AXFR to approved secondary servers, implement TSIG where supported, enforce network controls, separate internal and external DNS, maintain DNS software, and monitor suspicious requests. DNSSEC can strengthen DNS data integrity but cannot independently prevent unauthorized zone transfers. Reassessment should confirm that unauthorized transfers are denied while legitimate replication continues to work.

Code of Conduct:

I Yoga Madha A/192425058 *(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

Signature of the student: 

RUBRICS FOR CALCULATION

Report Analysis

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Report Analysis and Interpretation	25%	Accurately interprets the security report, identifies all key findings, and explains their significance with excellent technical understanding.	Correctly interprets most findings with minor omissions or inaccuracies.	Identifies only some findings and provides limited interpretation.	Unable to interpret the report or identify key findings.
Identification of Security Risks and Vulnerabilities	25%	Correctly identifies all security risks, vulnerabilities, and possible attack vectors with clear technical justification.	Identifies most risks and vulnerabilities with minor errors.	Identifies only a few risks with limited technical explanation.	Fails to identify major risks or vulnerabilities.

Application of Cybersecurity Concepts and Countermeasures	30%	Applies appropriate ethical hacking concepts and recommends comprehensive, practical, and technically sound countermeasures.	Recommends suitable countermeasures with minor technical gaps.	Provides limited or partially appropriate recommendations.	Recommendations are inappropriate, incomplete, or missing.
Technical Communication and Documentation	20%	Response is well organized, technically accurate, clearly presented, and uses appropriate cybersecurity terminology throughout.	Response is organized and understandable with minor documentation or presentation issues.	Response lacks clarity, organization, or contains several technical inaccuracies.	Response is poorly organized, incomplete, and difficult to understand.